

S11L5 - Esercizio 2

Studio IOC — Analisi Sandbox ANY.RUN

1. Identificazione del campione

Nome file: Jvczfhe.exe

Origine: scaricato da un repository GitHub pubblico
(github.com/MELITERRER/frew/blob/main/Jvczfhe.exe)

Verdetto ANY.RUN: Malicious activity

Tag: github, netreactor

SHA256:

0307EE805DF8B94733598D5C3D62B28678EAEADB1CA3689FA678A3780DD3DF0

MD5: 00B5E91B42712471CDFBDB37B715670C

Sistema operativo di analisi: Windows 10 Professional (build 19045, 64 bit)

General Info

URL:	https://github.com/MELITERRER/frew/blob/main/Jvczfhe.exe
Full analysis:	https://app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281
Verdict:	Malicious activity
Analysis date:	August 25, 2024 at 22:38:59
OS:	Windows 10 Professional (build: 19045, 64 bit)
Tags:	github netreactor
Indicators:	
MD5:	00B5E91B42712471CDFBDB37B715670C
SHA1:	D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2
SHA256:	0307EE805DF8B94733598D5C3D62B28678EAEADB1CA3689FA678A3780DD3DF0
SSDEEP:	3:N8tEd7QyQ3FJMERCNuN:2uRQyQ3zMsCNa

Il file è stato scaricato da GitHub, da un repository chiamato MELITERRER/frew.

Il sandbox ha calcolato l'hash del file e gli ha dato un verdetto: "Malicious activity", cioè "comportamento malevolo".

Il file ha anche due "tag" (etichette): github (da dove arriva) e netreactor.

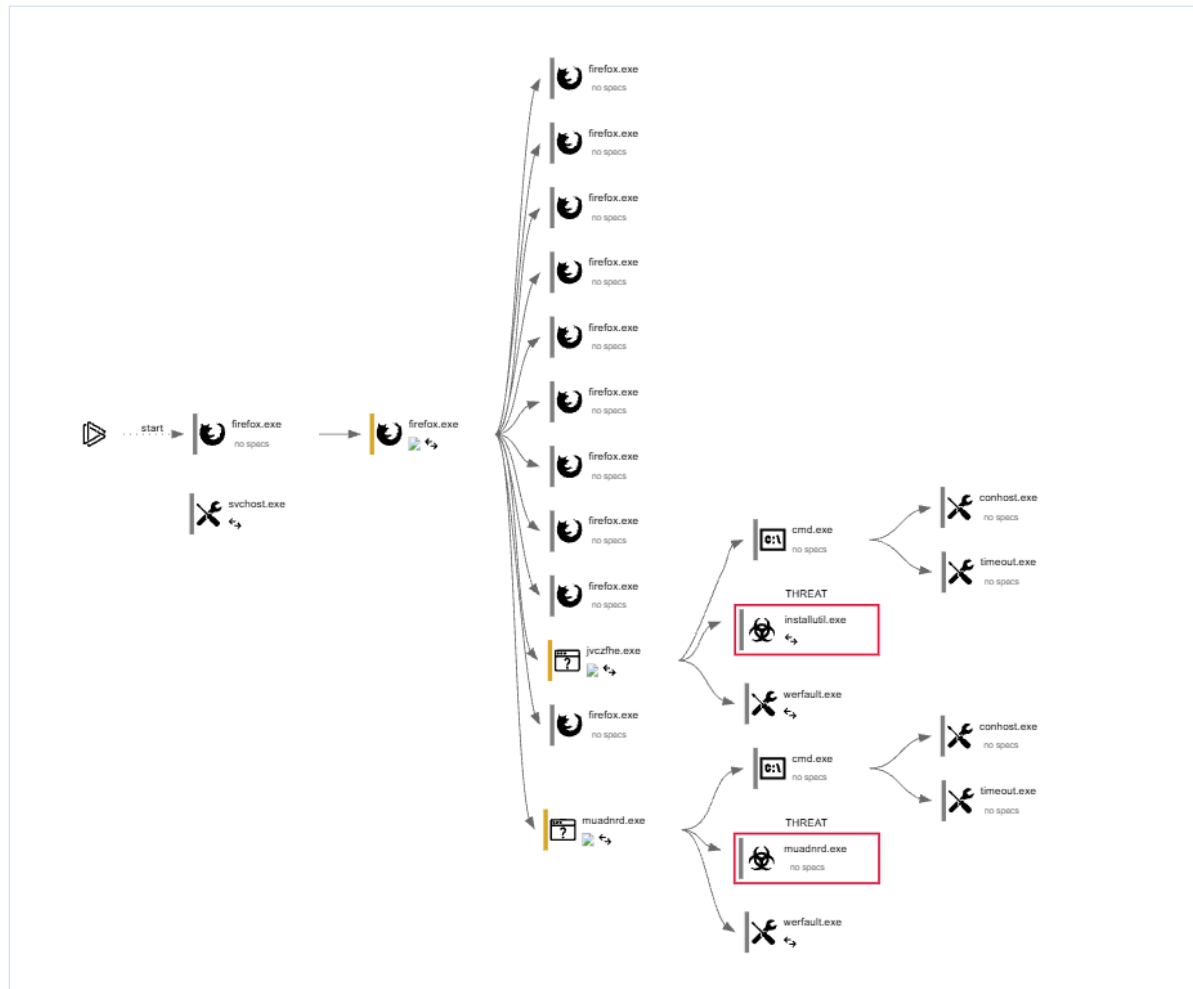
.NET Reactor è un programma commerciale che serve a "proteggere" un software scritto in .NET (un framework Microsoft per creare applicazioni Windows) rendendone il codice illeggibile a chi lo apre con un editor di testo o un decompilatore. Di per sé non è illegale: alcune aziende lo usano per proteggere codice proprietario legittimo.

Il problema è che i creatori di malware lo usano moltissimo per lo stesso identico motivo per cui lo userebbe un'azienda onesta: nascondere cosa fa davvero il programma, in modo che gli analisti di sicurezza (o gli antivirus) facciano più fatica a capirlo guardando il codice.

Trovare questo "protettore" su un file sospetto è quindi un forte indizio, anche se da solo non basta a dire "è malware".

2. Catena di esecuzione dei processi

Behavior graph



Dall'analisi dei processi monitorati (155 processi totali, 25 monitorati, 3 sospetti) emerge la seguente catena:

1. Jvczfhe.exe viene eseguito (il file scaricato da GitHub)
2. Questo lancia InstallUtil.exe
3. Lancia anche Muadnrd.exe
4. Alla fine interviene WerFault.exe

InstallUtil.exe è un programma originale di Microsoft, incluso in Windows come parte del .NET Framework. Serve normalmente per installare servizi software in modo legittimo. Il problema è che questo programma, può essere sfruttato per eseguire codice malevolo facendolo passare per un'attività normale, perchè Windows "si fida" di InstallUtil.exe essendo un file firmato Microsoft.

Questa tecnica ha anche un nome tecnico riconosciuto a livello internazionale: si chiama T1218.004 nel framework MITRE ATT&CK.

Muadnrd.exe ha un nome strano, tipico di file generati automaticamente da un malware. Nel report si vede che questo processo:

- viene protetto anch'esso da .NET Reactor
- si "auto-rilancia" (cioè lancia una copia di se stesso) — comportamento tipico di malware che cerca persistenza o che tenta di "sopravvivere" a un tentativo di chiusura

Nel gergo della sicurezza, un file che scarica o lancia altri file malevoli si chiama "dropper" (letteralmente "chi fa cadere/rilascia" qualcosa). Muadnrd.exe si comporta esattamente così.

WerFault.exe è il programma legittimo di Windows che si attiva automaticamente quando un'applicazione va in crash (è quello che genera la finestra "Questo programma ha smesso di funzionare"). Nel report vediamo che sia Jvczfhe.exe sia Muadnrd.exe vanno in crash durante l'esecuzione. Questo è comune nei malware offuscati: a volte il codice protetto è talmente compattato/nascosto che va in errore, oppure il malware stesso rileva di essere dentro un ambiente sandbox e "si rompe" volontariamente per evitare di rivelare tutto il suo comportamento a chi lo sta analizzando.

3. Tecniche di comportamento sospette osservate

Behavior activities

☒ Add for printing

MALICIOUS

No malicious indicators.

SUSPICIOUS

Process drops legitimate windows executable

- firefox.exe (PID: 6596)

Starts CMD.EXE for commands execution

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Uses TIMEOUT.EXE to delay execution

- cmd.exe (PID: 7520)
- cmd.exe (PID: 7876)

Reads security settings of Internet Explorer

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Executes application which crashes

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Checks Windows Trust Settings

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Connects to unusual port

- InstallUtil.exe (PID: 5152)

Application launched itself

- Muadnrd.exe (PID: 7824)

INFO

Application launched itself

- firefox.exe (PID: 6596)
- firefox.exe (PID: 6552)

Executable content was dropped or overwritten

- firefox.exe (PID: 6596)

Reads Microsoft Office registry keys

- firefox.exe (PID: 6596)

Reads the computer name

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)
- Muadnrd.exe (PID: 7248)

Checks supported languages

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)
- Muadnrd.exe (PID: 7248)

Reads Environment values

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)

Checks proxy server information

- Jvczfhe.exe (PID: 7492)
- WerFault.exe (PID: 1356)
- Muadnrd.exe (PID: 7824)
- WerFault.exe (PID: 7584)

Reads the machine GUID from the registry

- Jvczfhe.exe (PID: 7492)
- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7824)
- Muadnrd.exe (PID: 7248)

Reads the software policy settings

- Jvczfhe.exe (PID: 7492)
- WerFault.exe (PID: 1356)
- Muadnrd.exe (PID: 7824)
- WerFault.exe (PID: 7584)

Disables trace logs

- Jvczfhe.exe (PID: 7492)
- Muadnrd.exe (PID: 7824)

Creates files or folders in the user directory

- WerFault.exe (PID: 1356)
- WerFault.exe (PID: 7584)

.NET Reactor protector has been detected

- InstallUtil.exe (PID: 5152)
- Muadnrd.exe (PID: 7248)

Il report non segnala indicatori nella categoria "Malicious", ma numerosi indicatori "Suspicious", che nel complesso delineano un comportamento tipico di malware:

- Avvio di CMD.EXE per l'esecuzione di comandi da parte di Jvczfhe.exe e Muadnrd.exe
- Uso di TIMEOUT.EXE per ritardare l'esecuzione — tecnica di evasione sandbox/analisi automatizzata
- Lettura delle impostazioni di sicurezza di Internet Explorer e dei Windows Trust Settings — tipico di malware che verifica la configurazione di sicurezza del sistema prima di agire
- Rilevamento della protezione .NET Reactor su InstallUtil.exe e Muadnrd.exe — offuscamento del codice
- Connessione a una porta insolita da parte di InstallUtil.exe
- Disabilitazione dei trace log da parte di Jvczfhe.exe e Muadnrd.exe — tentativo di evitare la telemetria/logging di sistema

4. Indicatori di rete e infrastruttura C2

L'indicatore di rete più significativo emerge dalla sezione Threats del report, generato dal processo di sistema svchost.exe:

ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain

Threats			
PID	Process	Class	Message
2256	svchost.exe	Not Suspicious Traffic	INFO [ANY.RUN] Attempting to access raw user content on GitHub
2256	svchost.exe	Not Suspicious Traffic	INFO [ANY.RUN] Attempting to access raw user content on GitHub
2256	svchost.exe	Not Suspicious Traffic	INFO [ANY.RUN] Attempting to access raw user content on GitHub
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain
2256	svchost.exe	Potentially Bad Traffic	ET INFO DYNAMIC_DNS Query to a *.duckdns .org Domain
2256	svchost.exe	Misc activity	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain

DuckDNS è un servizio gratuito di dynamic DNS. Pur essendo un servizio legittimo, è frequentemente abusato come infrastruttura di Command & Control (C2) da malware e RAT (Remote Access Trojan), perché consente all'attaccante di aggiornare dinamicamente l'IP del server senza possedere un dominio fisso e senza costi di registrazione, rendendo più difficile il blocco basato su indirizzo IP.

Le altre connessioni osservate (github.com, ocsp.sectigo.com, r10/r11.o.lencr.org, detectportal.firefox.com, ecc.) sono traffico generato da Firefox durante il download del file e verifiche di certificati OCSP: rumore ambientale della sandbox, non indicatori malevoli in sé.

5. Conclusione

Preso singolarmente, nessun elemento costituisce una prova definitiva della natura malevola del file, ed è per questo che ANY.RUN non segna nulla come "Malicious" nella sua classificazione automatica. Ma la somma di tutti questi indizi, presi insieme, descrive un comportamento coerente:

- un file scaricato da un servizio pubblico (GitHub),
- offuscato per nascondere il proprio codice (.NET Reactor),
- che abusa di uno strumento legittimo di Windows per eseguire azioni (InstallUtil.exe),
- mette in atto tecniche per rallentare/ostacolare l'analisi (timeout, disattivazione log),
- infine comunica con un server esterno tramite un'infrastruttura tipicamente usata per il comando e controllo remoto (DuckDNS).

Questo è esattamente il comportamento che ci si aspetterebbe da un **loader** (un piccolo programma il cui unico scopo è scaricare/eseguire il "vero" malware) o da un **RAT** (Remote Access Trojan, un malware che dà a un attaccante il controllo remoto del PC infetto).

Gianpaolo Scagione